

Project Report Format

Script-Controlled ACL – Restrict Record Access Based on Field Value

Team ID: SWTID-2026-4457 | Date: 01 Oct 2026

1. INTRODUCTION

1.1 Project Overview

This project implements record-level security on the ServiceNow platform using a **script-controlled Access Control List (ACL)**. A custom table, **Institution Details** (`u_institution_details`), stores student and faculty information together with a **Branch** choice field (ECE, EEE, CSE). ACLs then decide who can read, create, write and delete these records.

In the implemented scenario, only users who hold the custom role **bb1** can view records whose Branch is **EEE**, users without the role see no records at all, and administrators retain full access. Further ACLs add create (bb2), write (bb3) and delete (bb4) control, so that each operation is governed by its own role.

1.2 Purpose

The purpose of the project is to demonstrate how roles, data conditions and server-side scripts are evaluated together to protect sensitive data from unauthorised viewing, modification, creation and deletion. It gives learners hands-on practice with the ServiceNow security model: users and roles, custom tables, security_admin elevation, ACL creation, impersonation and verification.

- Restrict visibility of records based on the value of a field (Branch).
- Separate the four record operations (read, create, write, delete) using dedicated roles.
- Preserve full administrative access through an explicit admin check.

2. IDEATION PHASE

2.1 Problem Statement

Educational and enterprise data often sits in a single table, yet different departments should only see their own records. Without field-level conditions, any user who can open the table can read every record.

	Problem Statement 1	Problem Statement 2
I am	An institution administrator	A faculty member of the EEE branch
I'm trying to	Make sure only authorised users can view branch-specific student records	View and maintain the records of EEE students
But	Every user with access to the table can see records of all branches	I may be blocked, or I may see data that belongs to other branches
Because	The table has no record-level rules tied to the Branch value	Role-based access is not combined with a data condition
Which makes me feel	Worried about data privacy and non-compliance	Frustrated and uncertain about data accuracy

2.2 Empathy Map Canvas

Persona: **Institution administrator** responsible for student data security.

SAYS "Only EEE staff should see EEE student records." "I need to control who can edit or delete data."	THINKS Can one table safely hold all branches? Will a mistake expose personal contact details?
DOES Creates roles, assigns them to users, writes ACLs, impersonates users to test the result.	FEELS Anxious about leakage of emails and phone numbers; confident once each role is verified.
PAINS Unrestricted list views, manual checks, unclear who can delete records.	GAINS Branch-wise privacy, least-privilege access, easy-to-verify behaviour, admin control retained.

2.3 Brainstorming

The team compared several ways to restrict access to branch-specific records before choosing the approach.

Idea	Description	Decision
Client-side hiding	Hide fields or rows with client scripts or UI policies.	Rejected – only affects the UI and is not real security.
Role-only ACL	Allow read for a single role without any condition.	Rejected – the role would see all branches.
Query business rule	Filter rows with a before-query rule.	Considered – works, but harder to maintain than ACLs.
Script-controlled ACL with data condition	Combine role, Branch is EEE condition and a script on the table ACL.	Selected – enforced on the server for lists, forms and portal.
Separate ACL per operation	Use bb2, bb3, bb4 for create, write and delete.	Selected – fine-grained least-privilege control.

3. REQUIREMENT ANALYSIS

3.1 Customer Journey map

Stage	Administrator action	Touchpoint	Experience	Opportunity
Prepare	Logs in as admin, plans roles and table	ServiceNow instance	Neutral – needs clear plan	Define bb1–bb4 up front
Configure	Creates EEE User, roles bb1–bb4, table and sample records	Users, Roles, Tables modules	Positive – steps are guided	Reuse naming conventions
Secure	Elevates security_admin, creates Read/Create/Write/Delete ACLs	Access Control (ACL) module	Careful – high-privilege area	Test each ACL after creation
Verify	Impersonates EEE User and Admin, opens u_institution_details.list	List view	Confident when results match	Document expected results
Operate	Assigns roles to real users, monitors access	Role assignment, audit	Satisfied – data protected	Add reports and audits

3.2 Solution Requirement

Functional requirements

ID	Requirement
FR-1	Create a test user (EEE User) and custom roles bb1, bb2, bb3, bb4; assign all roles to the user.
FR-2	Create the table Institution Details (u_institution_details) with Roll Number, Student Name, Faculty Name, Branch, Email, Phone Number and Description.
FR-3	Populate records with different Branch values (ECE, EEE, CSE).
FR-4	Read ACL: only bb1 users see records where Branch is EEE; admin sees all.
FR-5	Create, Write and Delete ACLs require bb2, bb3 and bb4 respectively.
FR-6	Users without the relevant role see no records and cannot modify data.

Non-functional requirements

Attribute	Requirement
Security	Rules enforced on the server; admin override preserved; ACL changes need security_admin elevation.
Usability	Behaviour is identical in list view and form, and verifiable through impersonation.
Maintainability	One ACL per operation; roles named consistently; script kept short and commented.
Performance	Script contains only role checks so evaluation stays lightweight.

3.3 Data Flow Diagram

The diagram shows how a list request travels through the ACL engine before records are returned.

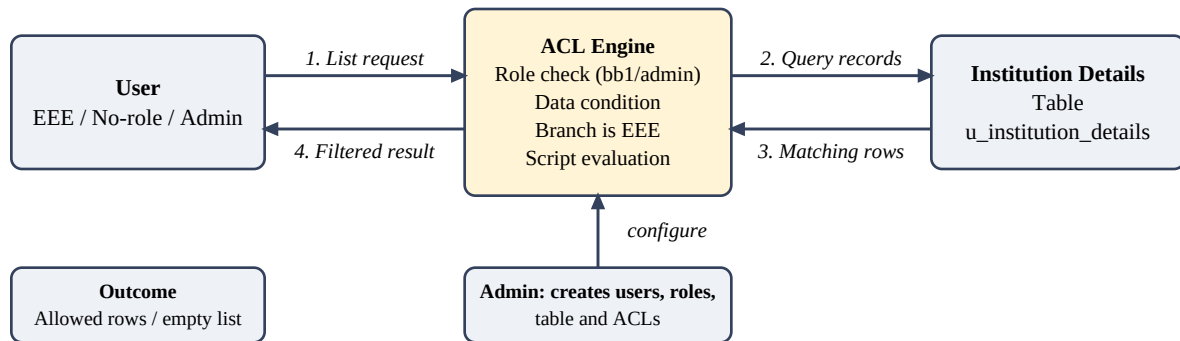


Figure 1: Data flow diagram

3.4 Technology Stack

Layer	Technology / Feature
Platform	ServiceNow instance (application scope: Global, update set "ACL Project")
Identity	User Administration – Users, Roles, Impersonate user, Elevate role (security_admin)
Data	Custom table u_institution_details; field types: Reference (User), Choice, String, Multi-line text, Auto Number
Security	Access Control Lists (type record; operations read, create, write, delete); data condition; advanced script
Scripting	Server-side JavaScript (ECMAScript) using GlideSystem method gs.hasRole()
Testing	Impersonation and list view u_institution_details.list

4. PROJECT DESIGN

4.1 Problem Solution Fit

Problem	Solution	Fit
All users can read all branch records	Read ACL with data condition Branch is EEE and a role/script check	Only intended rows are returned
Unclear who may add, edit or remove data	Separate Create (bb2), Write (bb3), Delete (bb4) ACLs	Least privilege per operation
Administrators could be locked out	Script explicitly returns true for admin	Admin keeps full access
Hard to prove security works	Impersonate bb1 user, no-role user and admin and compare lists	Evidence-based verification

4.2 Proposed Solution

A script-controlled read ACL is placed on the Institution Details table. It is marked **Advanced**, requires the **bb1** role, carries the data condition **Branch is EEE**, and uses a script to return true for admin or bb1 and false otherwise. Three additional ACLs gate record creation, editing and deletion. The ACLs together are summarised below.

ACL operation	Required role	Data condition	Script	Result
read	bb1	Branch is EEE	Yes (Advanced)	bb1 sees EEE rows only; admin sees all
create	bb2	None	No	New button available
write	bb3	None	No	Fields editable in list/form
delete	bb4	None	No	Delete action available

4.3 Solution Architecture

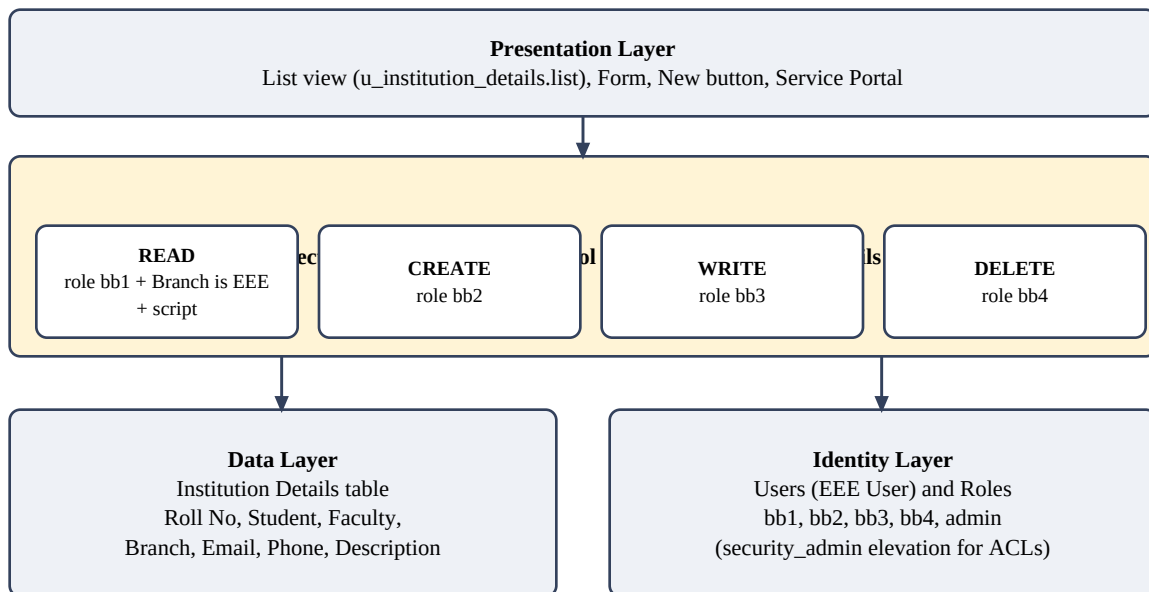


Figure 2: Solution architecture

A request from the presentation layer is checked by the ACLs in the security layer, which use the user's roles from the identity layer. Only rows that pass are read from the data layer and shown.

5. PROJECT PLANNING & SCHEDULING

5.1 Project Planning

The lab is scheduled for 3 hours. The work was split into milestones with the estimated effort below.

Milestone	Activities	Estimated time	Status
1. Users and roles	Create EEE User; create roles bb1–bb4; assign roles	30 min	Completed
2. Table creation	Create u_institution_details; add 7 fields; insert records	35 min	Completed
3. Read ACL	Elevate security_admin; create script-controlled read ACL; verify	40 min	Completed
4. Create ACL	Create ACL for bb2; verify New button	25 min	Completed
5. Write ACL	Create ACL for bb3; verify inline edit	25 min	Completed
6. Delete ACL	Create ACL for bb4; verify delete action	25 min	Completed

Estimates add up to 3 hours.

6. FUNCTIONAL AND PERFORMANCE TESTING

6.1 Performance Testing

Because this is a rule-based security solution rather than a trained model, performance is measured as the share of access scenarios that behave as expected. Each test was executed by impersonating the relevant user and opening the Institution Details list.

ID	Scenario	Expected result	Actual result	Status
TC-1	User with bb1 opens the list	Only EEE records (2)	2 EEE records shown	Pass
TC-2	User without bb1 opens the list	No records	"No records to display"	Pass
TC-3	Admin opens the list	All records (5)	5 records shown	Pass
TC-4	bb1 + bb2 user views list	EEE rows and New button	2 rows, New button visible	Pass
TC-5	bb1 + bb2 + bb3 user edits Description	Inline edit allowed	Description updated	Pass
TC-6	bb1–bb4 user deletes a record	Delete action and confirmation available	Delete option and dialog shown	Pass

Result: 6 of 6 test cases passed (100% validation accuracy). Training accuracy is not applicable as no model is trained.

7. RESULTS

7.1 Output Screenshots

User ID: EEEUser
First name: EEE
Last name: User
Title:
Department:
Location:
Email: eeeuser@gmail.com
Identity type: Human
Language: -- None --
Calendar integration: Outlook
Time zone: System (Asia/Kolkata)
Date format: System (yyyy-MM-dd)
Business phone:
Mobile phone:
Active: ☒
Internal integration User: ☐
Update Set Password Delete

Figure 3: Creation of the test user (EEE User)

Name: BB1
Application: Global
Elevated privilege: ☐
Description:
Update Delete

Figure 4: Creation of role bb1 (bb2, bb3 and bb4 created the same way)

Label: Institution Details
Name: u_institution_details
Application: Global
Remote Table:
Delete Update Delete All Records

Figure 5: Custom table Institution Details (u_institution_details)

Column label	Type	Reference	Max length	Default value
Updates	Integer	(empty)	40	
Created by	String	(empty)	40	
Student Roll Number	String	(empty)	40	javascript:global.getNextObjNumberPadded();
Description	String	(empty)	1,000	
Updated by	String	(empty)	40	
Phone Number	String	(empty)	40	
Sys ID	Sys ID (GUID)	(empty)	32	
Created	Date/Time	(empty)	40	
Faculty name	Reference	User	32	
Branch	String	(empty)	40	
Updated	Date/Time	(empty)	40	
Student Name	Reference	User	32	
Email	String	(empty)	40	

Figure 6: Table columns (dictionary entries)

institution Details Student Roll Numbe Search						
All						
☐	Student Roll Number	Faculty name	Student Name	Branch	Email	Phone Number
	Search	Search	Search	Search	Search	Search
	71005	Alfonso Griglen	Willard Roughen	EEE	willard.roughen@example.com	7234924254
	71001	Alissa Mountjoy	Abel Tuter	CSE	abel.tuter@example.com	9432154538
	71003	Beverley Bunche	Bess Marso	EEE	bess.marso@example.com	9784657345
	71002	Allie Pumphrey	Andrew Och	ECE	andrew.och@example.com	7690984354
	71004	Allan Schwandt	Abraham Lincoln	CSE	abraham.lincoln@example.com	9467469879

Figure 7: Sample records with ECE, EEE and CSE branches

Elevate role

[Close dialog](#)

Elevate a role by adding privileges, which end when you log out. [Learn more](#)

AVAILABLE ROLES

☒ security_admin

Grant modification access to High Security Settings, allow user to modify the Access Control List

Cancel

Update

Figure 8: Elevating the security_admin role

Access Control

u_institution_details

Update

Delete

* Type

record

* Operation

read

Decision Type

Allow If

Admin overrides

☒

Application

Global

Active

☒

Advanced

☒

Protection policy

-- None --

* Name

Institution Details [u_institution_details]

-- None --

Description

Applies To

No. of records matching the condition: 5

Add Filter Condition

Add OR Clause

-- choose field --

-- oper --

-- value --

Figure 9: Read ACL – type, operation, name and Advanced option

Data Condition

Condition No. of records matching the condition: 2

Add Filter Condition Add OR Clause

Branch is EEE

AND OR X

Advanced Condition

Controlled by References

Script Turn on ECMAScript 2021 (ES12) mode

```

1
2
3 (function() {
4     if (gs.hasRole('bb1')) {
5         return true;
6     } else {
7         return false;
8     }
9 })();

```

Figure 10: Data condition (Branch is EEE) and the ACL script

Student Roll Number	Branch	Description	Email	Faculty name	Phone Number	Student Name
71005	EEE	coordinator	willard.roughen@example.com	Alfonso Griglen	7234924254	Willard Roughen
71003	EEE	Representative	bess.marso@example.com	Beverley Bunche	9784657345	Bess Marso

Figure 11: bb1 user sees only EEE records

Student Roll Number	Branch	Description	Email	Faculty name	Phone Number	Student Name
Search	Search	Search	Search	Search	Search	Search



No records to display

Figure 12: User without the role sees no records

Student Roll Number	Faculty name	Student Name	Branch	Email	Phone Number
Search	Search	Search	Search	Search	Search
71005	Alfonso Griglen	Willard Roughen	EEE	willard.roughen@example.com	7234924254
71001	Alicia Mountjoy	Abel Tuter	CSE	abel.tuter@example.com	9432154538
71003	Beverley Bunche	Bess Marso	EEE	bess.marso@example.com	9784657345
71002	Allie Pumphrey	Andrew Och	ECE	andrew.och@example.com	7690984354
71004	Allan Schwandt	Abraham Lincoln	CSE	abraham.lincoln@example.com	9467469879

Figure 13: Admin sees all records

Access Control
u_institution_details

* Type: record

* Operation: create

Decision Type: Allow If

Application: Global

Active: ☒

Admin overrides: ☒

Protection policy: -- None --

* Name: Institution Details [u_institution_details]

Description:

Applies To: No. of records matching the condition: 5

[Add Filter Condition](#) [Add OR Clause](#)

-- choose field -- -- oper -- -- value --

Figure 14: Create ACL (operation create)

Conditions

Access Control Rules have two decision types, and these types will behave differently depending on conditions.

1. Allow Access: Allows access to a resource if all conditions are met. Additional ACLs may grant access to records where this ACL has not granted access.

2. Deny Access: Denies access to a resource unless all conditions are met. Additional ACLs may not grant access to records where this ACL has denied access.

[More Info](#)

Requires role
Role
BB2
Insert a new row...

Security Attribute Condition

Figure 15: Create ACL requires role bb2

institution Details

Student Roll Number

Search

Actions on selected rows... [New](#)

Student Roll Number	Branch	Description	Email	Faculty name	Phone Number	Student Name
71005	EEE	coordinator	willard.roughen@example.com	Alfonso Griglen	7234924254	Willard Roughen
71003	EEE	Representative	bess.marso@example.com	Beverley Bunche	9784657345	Bess Marso

Figure 16: bb1 + bb2 user sees EEE records and the New button

Access Control
u_institution_details

* Type: record

* Operation: write

Decision Type: Allow If

Application: Global

Active: ☒

Admin overrides: ☒

Protection policy: -- None --

* Name: Institution Details [u_institution_details]

Description:

Applies To: No. of records matching the condition: 5

[Add Filter Condition](#) [Add OR Clause](#)

-- choose field -- -- oper -- -- value --

Figure 17: Write ACL (operation write)

Access Control Rules have two decision types, and these types will behave differently depending on conditions.

1. Allow Access: Allows access to a resource if all conditions are met. Additional ACLs may grant access to records where this ACL has not granted access.
2. Deny Access: Denies access to a resource unless all conditions are met. Additional ACLs may not grant access to records where this ACL has denied access.

[More Info](#)

Requires role	
	Role
✕	BB3
Insert a new row...	

Figure 18: Write ACL requires role bb3

institution Details Student Roll Number Search							
All							
☐	Student Roll Number	Branch	Description	Email	Faculty name	Phone Number	Student Name
	71005	EEE		example.com	Alfonso Griglen	7234924254	Willard Roughen
	71003	EEE		mple.com	Beverley Bunche	9784657345	Bess Marso

Figure 19: Inline editing of Description enabled for bb3 user

Access Control New record

Warning: A role, security attribute, data condition, script or ACL control via reference fields is required to properly secure access with this ACL.

* Type: record

* Operation: delete

Decision Type: Allow If

Admin overrides: ☒

Protection policy: -- None --

* Name: Institution Details [u_institution_details] -- None --

Description:

Applies To: No. of records matching the condition: 5

Add Filter Condition Add OR Clause

-- choose field -- -- oper -- -- value --

Figure 20: Delete ACL (operation delete)

Requires role	
	Role
✕	BB4
Insert a new row...	

Security Attribute Condition

Figure 21: Delete ACL requires role bb4

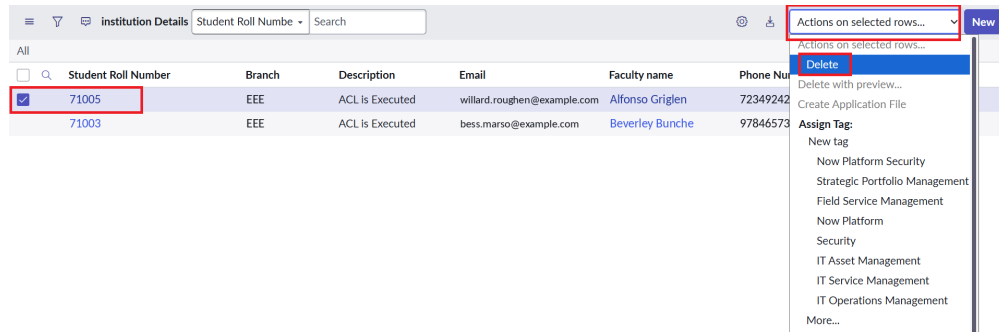


Figure 22: Delete action available for bb1–bb4 user

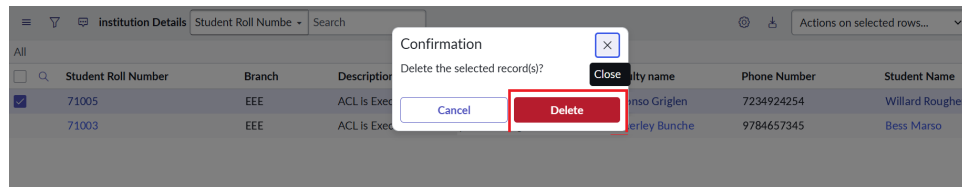


Figure 23: Delete confirmation dialog

8. ADVANTAGES & DISADVANTAGES

Advantages

- Security is enforced on the server, so it applies to lists, forms and the Service Portal alike.
- Branch-based privacy: users only see the rows they are meant to see.
- Each operation (read, create, write, delete) has its own role, supporting least privilege.
- Administrators keep full access through an explicit check.
- Uses standard platform features, with no extra licences or integrations.

Disadvantages

- The script grants access to any bb1 user; the Branch restriction depends on the data condition, so both must be kept in sync.
- Roles are fixed to the EEE branch; supporting ECE and CSE needs extra roles and ACLs.
- Create, write and delete ACLs have no data condition, so they are not limited by branch on their own.
- Managing many ACLs and roles adds administrative overhead, and ACL changes need security_admin elevation.
- Script-based ACLs need careful testing because mistakes can accidentally block or expose data.

9. CONCLUSION

The project showed that script-controlled ACLs on ServiceNow can restrict records by field value while keeping administrator access intact. Verification confirmed that a bb1 user sees only EEE records, a user without the role sees nothing, and an admin sees all records. The additional create, write and delete ACLs completed a full set of record-level controls, and all six test cases passed.

10. FUTURE SCOPE

- Add roles and ACLs for the ECE and CSE branches, ideally driven by a user attribute instead of one role per branch.
- Apply data conditions to the create, write and delete ACLs so changes are also branch-limited.
- Add field-level ACLs to protect Email and Phone Number.
- Group roles into containing roles or groups to simplify administration.
- Add audit reports and dashboards for access reviews, and expose the records through a Service Portal page.

11. APPENDIX

Source Code (if any)

Script used in the Advanced section of the read ACL on u_institution_details:

```
(function () {  
  // Allow admin users full access  
  if (gs.hasRole('admin')) {  
    return true;  
  }  
  // Allow only EEE branch users to see EEE records  
  if (gs.hasRole('bb1')) {  
    return true;  
  }  
  // Deny access for all others  
  return false;  
})();
```

Dataset Link

No external dataset was used. Sample records were created directly in the Institution Details table:

Roll Number	Student Name	Faculty Name	Branch	Description	Email	Phone
71005	Willard Roughen	Alfonso Griglen	EEE	coordinator	willard.roughen@example.com	7234924254
71001	Abel Tuter	Alissa Mountjoy	CSE	Student	abel.tuter@example.com	9432154538
71003	Bess Marso	Beverley Bunche	EEE	Representative	bess.marso@example.com	9784657345
71002	Andrew Och	Allie Pumphrey	ECE	Student 2	andrew.och@example.com	7690984354
71004	Abraham Lincoln	Allan Schwandt	CSE	Assistant rep	abraham.lincoln@example.com	9467469879

GitHub & Project Demo Link

GitHub: <https://github.com/Dharshini0806/NM-Project-ACL->

Demo video: https://drive.google.com/file/d/1lC3eQZ41RHwjz8CBCXoDgGgz9i_R-Ko/view?usp=drivesdk